AS OF 2026,
~1.34 BILLION



WEBSITES

Internet Live Statistics (2026)

6 out of 10
WEBSITES



COMPROMISED

Scalify Media (2026)

~68%
OF BREACHES



UNFAMILIARITY

Verizon (2025)

AS OF 2026,
~1.34 BILLION



WEBSITES
Internet Live Statistics (2026)

6 out of 10
WEBSITES



COMPROMISED
Scalify Media (2026)

~68%
OF BREACHES



UNFAMILIARITY
Verizon (2025)

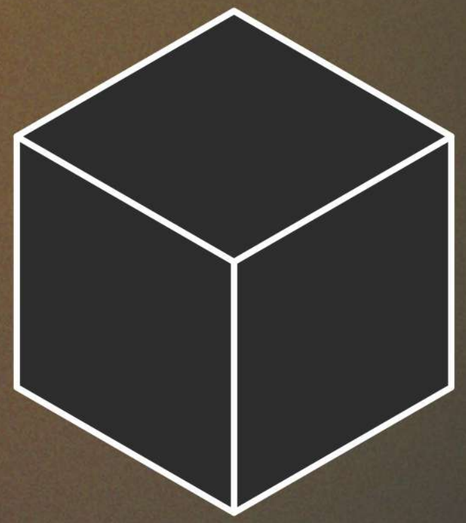


SOLUTIONS EXIST
BUT THEY ARE



NOISY

&



BLACK BOXES

AS OF 2026,
~1.34 BILLION



WEBSITES
Internet Live Statistics (2026)

6 out of 10
WEBSITES



COMPROMISED
Scalify Media (2026)

~68%
OF BREACHES



UNFAMILIARITY
Verizon (2025)

WHICH FAILS
TO SOLVE ANOTHER PROBLEM

CMSC 190: Special Problem 2

RINIG:
An Explainable AI-Assisted, Low-Noise Web Application Reconnaissance Framework for Developer Assistance

Adviser:

Joseph Anthony C. Hermocilla

Presented by

Erix Laud B. Reyes

THE ISOLATION TRADEOFF

STEALTH





EXPLAINABILITY

TRUST



ARE ALL FACTORS VIEWED AS **INDIVIDUAL FACTORS** TO A PROBLEM.

ALSHUDUKHI, ET AL. (2025)

THERE IS A NEED FOR A DEVELOPER-FIRST RECONNAISSANCE FRAMEWORK.

A HOLISTIC APPROACH RATHER ISOLATED SOLUTIONS.



RINIG

THE DEVELOPER-FIRST RECONNAISSANCE FRAMEWORK



RINIG
is not a perfect tool.

1

Only covers **Reconnaissance in Web Applications**

2

Speed is not the priority of this framework

3

The framework is **model-dependent**

RINIG

is a reconnaissance framework that

Develop an agent-centric web application reconnaissance framework that integrates noise reduction and explainability, equipping developers with a tool to identify and learn standard web security.

1. has **NOISE REDUCTION**



2. has **EXPLAINABILITY**



3. is built for **IDENTIFYING and LEARNING WEB SECURITY**

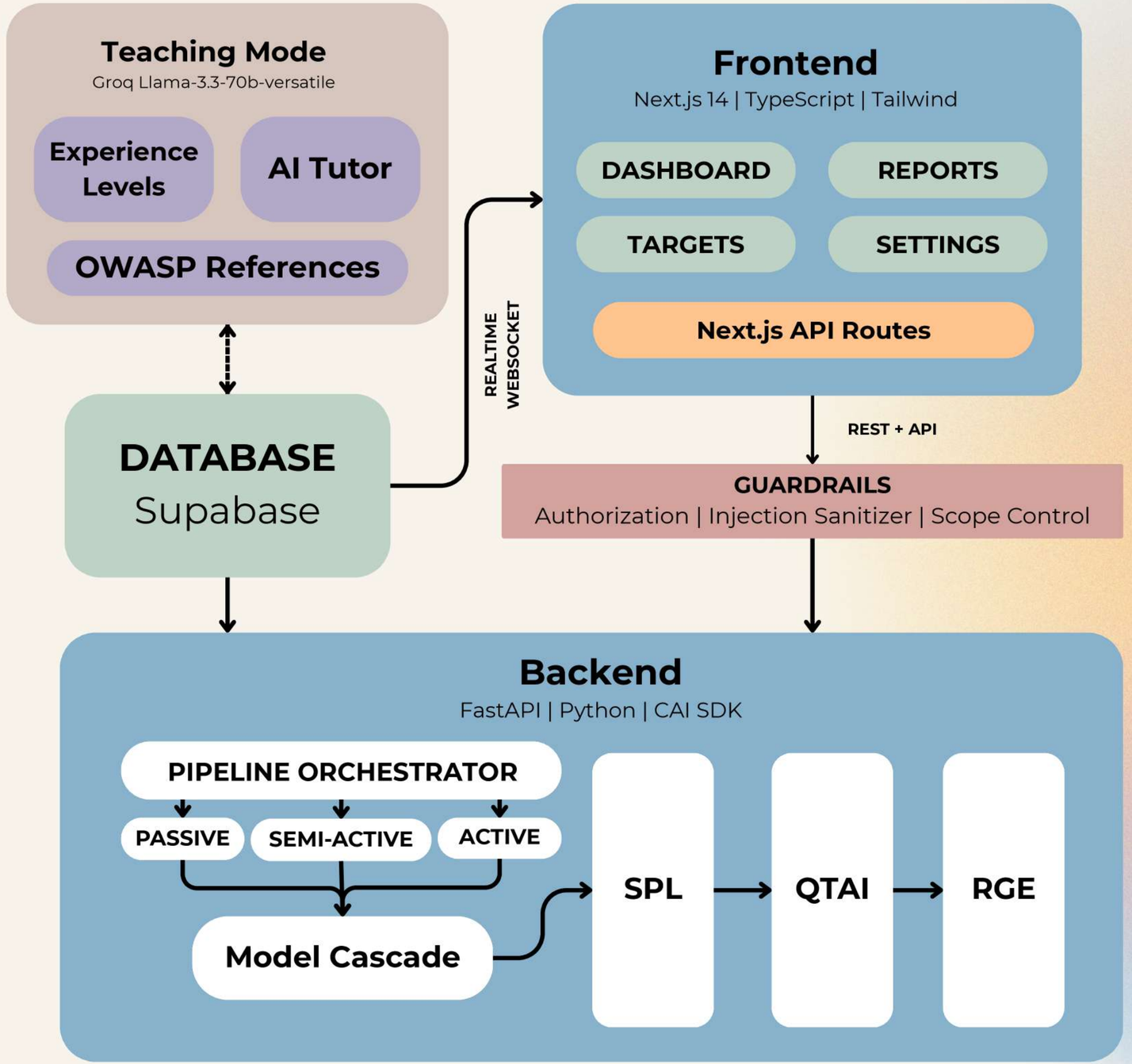


RINIG

THE ARCHITECTURE

TABLE I: Technology Stack of the RINIG Framework

Component	Technology / Language
Core Framework	Python (3.11+), CAI SDK (`cai-framework`)
Agent Model (Primary)	DeepSeek `deepseek-chat` via LiteLLM
Agent Model (Fallback)	Groq `llama-3.3-70b-versatile` → Gemini 2.5 Flash
Rationale Engine (RGE)	Gemini 2.5 Flash via OpenAI-compatible endpoint
Teaching Model	Groq `llama-3.3-70b-versatile` via `GROQ_API_KEY`
Frontend / Dashboard	Next.js 14 (App Router), TypeScript, Tailwind CSS, Framer Motion
Backend API	FastAPI (port 8000), REST + SSE streaming
Database	Supabase (PostgreSQL + Realtime WebSocket + Auth)



RINIG

THE PASSIVE OSINT TIER

8 modules

0.1 noise weight

Produces **no direct contact** with the target infrastructure.

TABLE III: Passive OSINT Tier

Module ID	Description
mod_dns_enum	6-source passive subdomain enumeration (crt.sh, HackerTarget, Anubis-DB, OTX AlienVault, ThreatMiner, urlscan.io) with Google DoH wordlist fuzzing and wildcard detection.
mod_domain_risk	RDAP domain age, expiry proximity, DNSSEC status, and registrar lock checks.
mod_cert	crt.sh Certificate Transparency log lookup for all issued SSL certificates on the target.
mod_osint_search	OTX AlienVault threat intelligence and HackerTarget host search.
mod_wayback_urls	Wayback Machine CDX API for historical URLs and sensitive path discovery.
mod_github_dork	GitHub code search for hardcoded secrets and credential leakage.
mod_email_harvest	Email address extraction from public-facing pages.
mod_cdn_hosting	CDN/WAF provider identification, cloud platform detection, and origin IP exposure via passive subdomain enumeration.

RINIG

THE SEMI-ACTIVE TIER

10 modules

0.3 noise weight

Produces **low frequency HTTP requests** to target infrastructure.

TABLE IV: Semi-Active Probing Tier

Module ID	Description
mod_http_headers	HSTS, CSP, cookie security flags, cross-origin isolation, and X-Frame-Options audit.
mod_tech_fp	30+ technology signatures via response headers, meta tags, and cookie fingerprinting.
mod_robots	robots.txt, sitemap variants, and .well-known path disclosure.
mod_waf	WAF presence detection via header and response body signatures.
mod_ssl_analysis	TLS version, cipher suite, certificate expiry, and HSTS analysis.
mod_cors_check	Wildcard origin, reflected origin, and credential-leaking CORS configuration tests.
mod_js_analysis	JavaScript endpoint extraction, GraphQL hints, WebSocket discovery, secrets regex, and proto-type pollution patterns.
mod_version_risk	Component version disclosure and known-risky version flag detection.
mod_cms_detect	WordPress, Drupal, and Joomla admin panel and configuration file exposure probing.
mod_web_service_probe	HTTP/HTTPS probe on 12 web ports (80, 443, 3000, 4443, 5000, 8000, 8080, 8443, 8888, 9000, 9090, 9443).

RINIG

THE SEMI-ACTIVE TIER

6 modules

0.6 noise weight

Produces **high-risk fuzzing and probing operations** generating high network footprints.

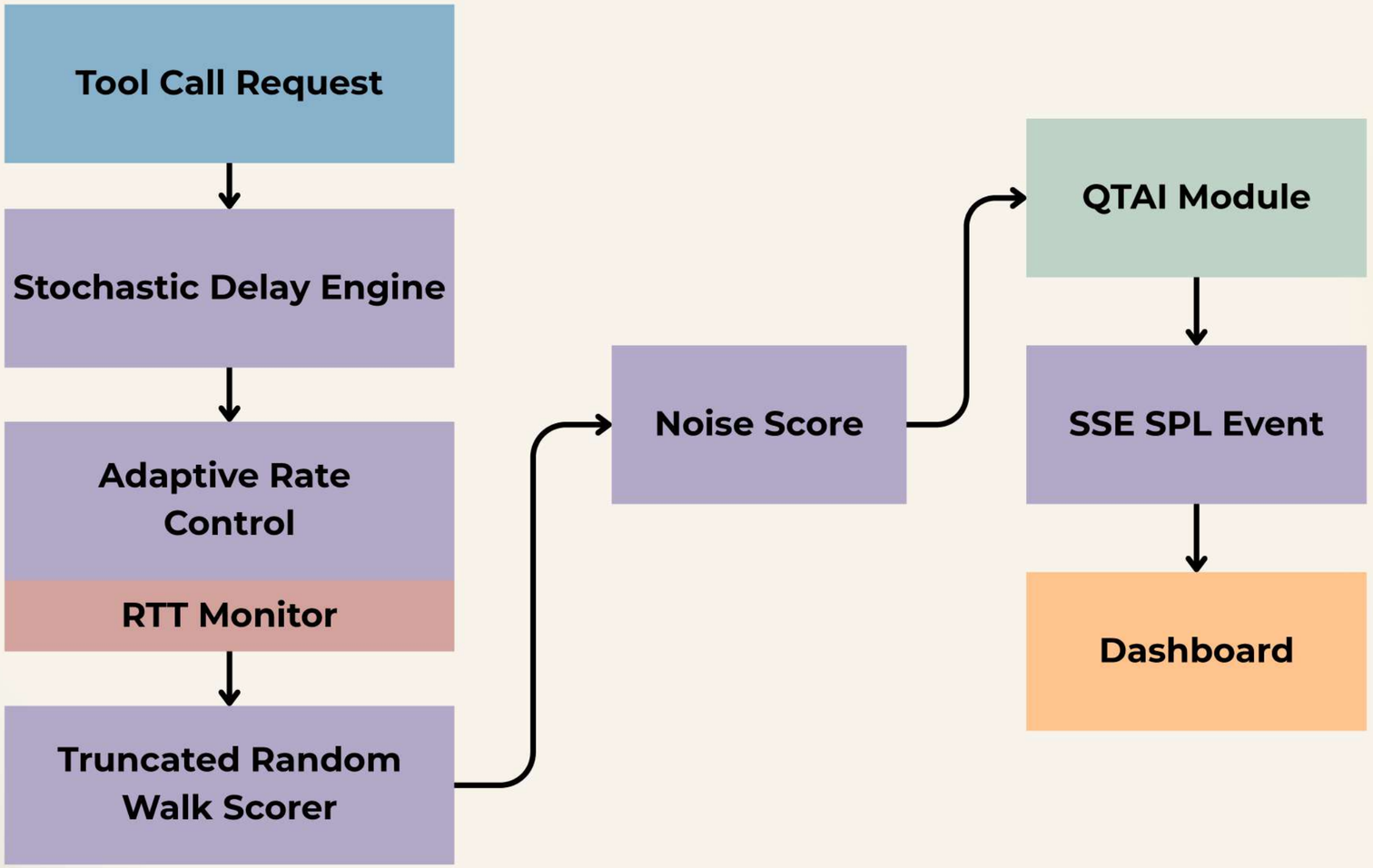
TABLE V: Active Scanner Tier

Module ID	Description
mod_nikto	Nikto safe scan (-Tuning 1234 -nointeractive) or Python fallback for environments without the Nikto binary.
mod_dir_ discov-ery	Gobuster directory enumeration with extension fuzzing (.php, .html, .js, .bak, .zip, .env, .conf). No recursive deep-search per stealth constraints.
mod_subdomain_ takeover	CNAME chain check for dangling DNS records across Heroku, GitHub Pages, and Netlify fin-gerprints.
mod_open_ redi-rect	20+ redirect parameter combinations tested for open redirect vulnerabilities.
mod_browser_ probe	XSS reflection, SQL injection indicators, SSTI with baseline comparison, and SSRF sink detec-tion.
mod_exposure_ probe	60+ sensitive paths including .git/.env/backups, Spring Boot Actuator (7 endpoints), Elastic-search, Jenkins, Kibana, cloud metadata, HTTP method abuse (TRACE/PUT/DELETE), and JWT/API key detection in response headers.

RINIG

THE LOW-NOISE IMPLEMENTATION

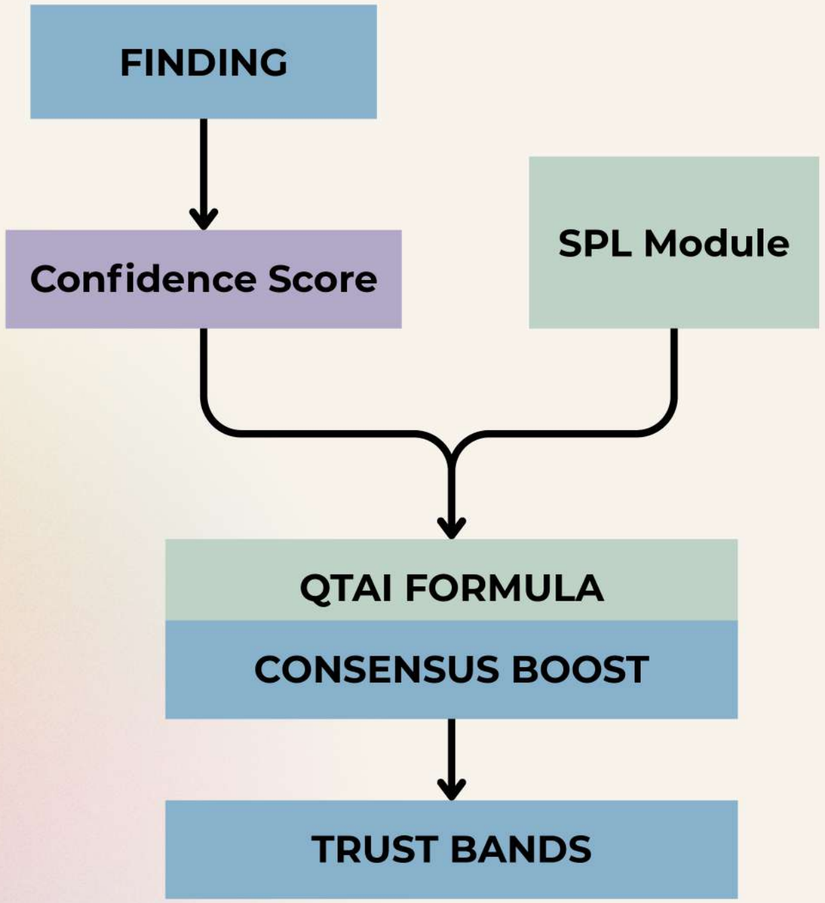
Stealth Policy Layer



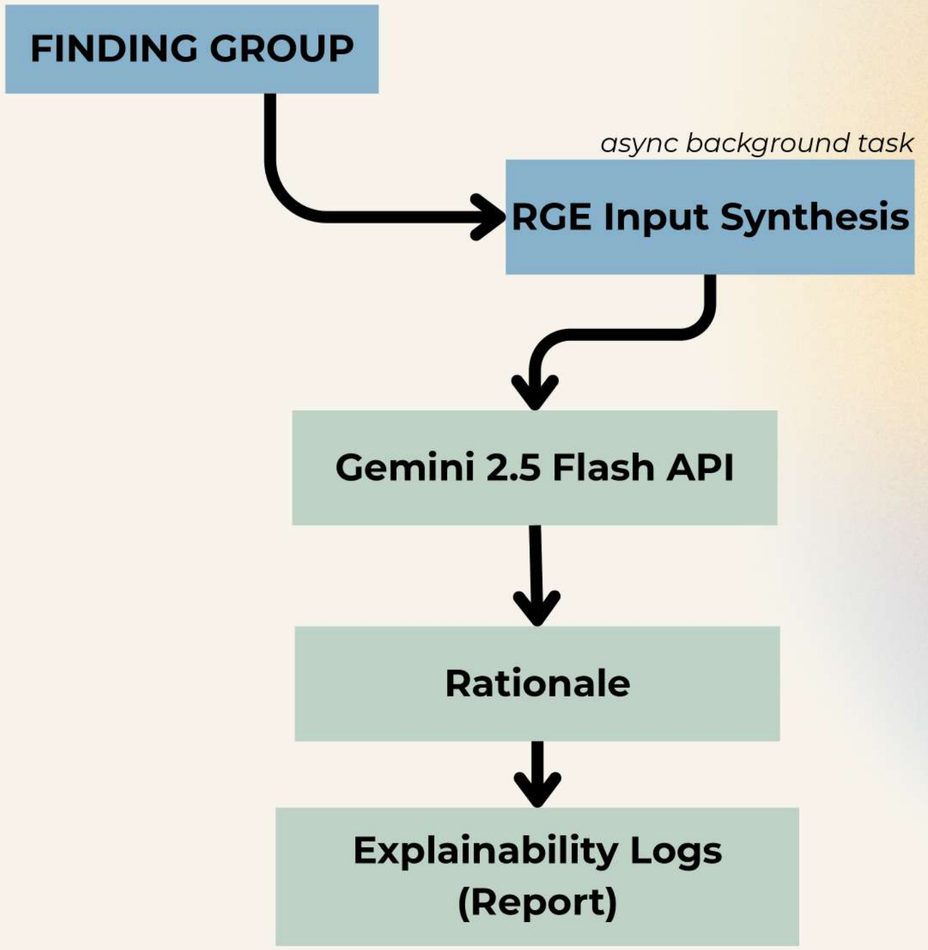
RINIG

THE EXPLAINABILITY IMPLEMENTATION

Quantifiable Trust & Accountability Index



Rationale Generation Engine



RINIG

THE ETHICAL MANDATE

3-LAYER GUARDRAIL STACK:

Authorization, Injection, and Scope

COMPLIANCE:

NIST SP 800-53 COMPATIBLE

OWASP Testing Guide v4.2

RINIG

COMPLETE METHODOLOGY

System Architecture and Platform

Module Registry and Tier Design

Low-Noise Implementation

XAI and Accountability Augmentation

Guardrails & Ethical Mandate

Prototyping

Evaluation and Validation

RINIG

RESULTS AND DISCUSSION

MIXED-METHOD APPROACH

1

DVWA & **WAF/IDS**

TECHNICAL BENCHMARKING

to test the operational effectiveness of the framework

2

12 out of 10 PARTICIPANTS

HUMAN-IN-THE-LOOP VALIDATION

to test the explainability of the framework

RINIG

RESULTS AND DISCUSSION

TECHNICAL BENCHMARKING 1

CONTROLLED TESTBEDS:



- Locally Deployed **Damn Vulnerable Website Application (DVWA)**
- **WAF/IDS-protected** environment using **ModSecurity** with **OWASP Core Rule Set (CRS)**

BASELINE:



Nikto

Nikto is a Website Vulnerability Scanner

RINIG

RESULTS AND DISCUSSION

TECHNICAL BENCHMARKING 1

TABLE VI: Technical Benchmark Results vs. Target Thresholds

Metric	Target	DVWA	WAF/IDS	Status
Detection Rate	$\geq 70\%$	78.3% (47/60)	72.1% (43/60)	MET
Mean Noise Score	< 0.30	0.187	0.214	MET
Stealth (Avoidance)	$\geq 80\%$	N/A	88.0% (22/25)	MET
Completion Time	< 15 min	11.4 min	13.1 min	MET
RGE Coverage	$\geq 90\%$	94.2%	92.7%	MET

DETECTION RATE: Reliability of the framework in finding risk profiles.

MEAN NOISE SCORE: Assesses the operational risk per scan.

STEALTH (AVOIDANCE): Assesses the efficiency of the SPL.

COMPLETION TIME: Gauges practicality for developer use.

RGE COVERAGE: Assesses the rationale generation per finding.

RINIG

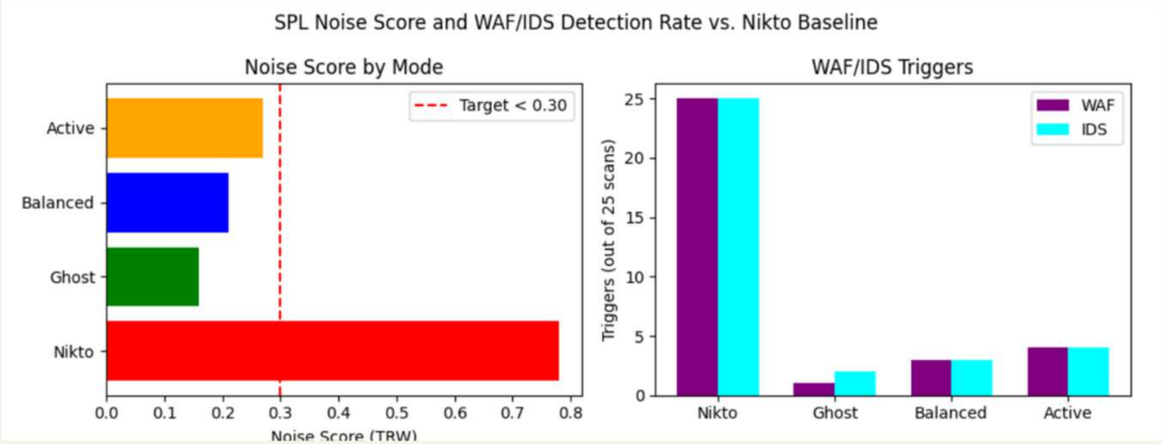
RESULTS AND DISCUSSION

TECHNICAL BENCHMARKING 1

ADDITIONAL EVIDENCE FOR NOISES REDUCTION:

TABLE VII: SPL Noise and Detection Comparison vs. Nikto Baseline

Metric	Nikto (no SPL)	Ghost (Exponential)	Balanced (Exp+Weibull)	Active (Weibull)
Mean Noise	0.78	0.16	0.21	0.27
WAF Triggers	25/25	1/25	3/25	4/25
IDS Alerts	25/25	2/25	3/25	4/25
Requests	∼1,200	∼210	∼310	∼420



RINIG

RESULTS AND DISCUSSION

TECHNICAL BENCHMARKING 1

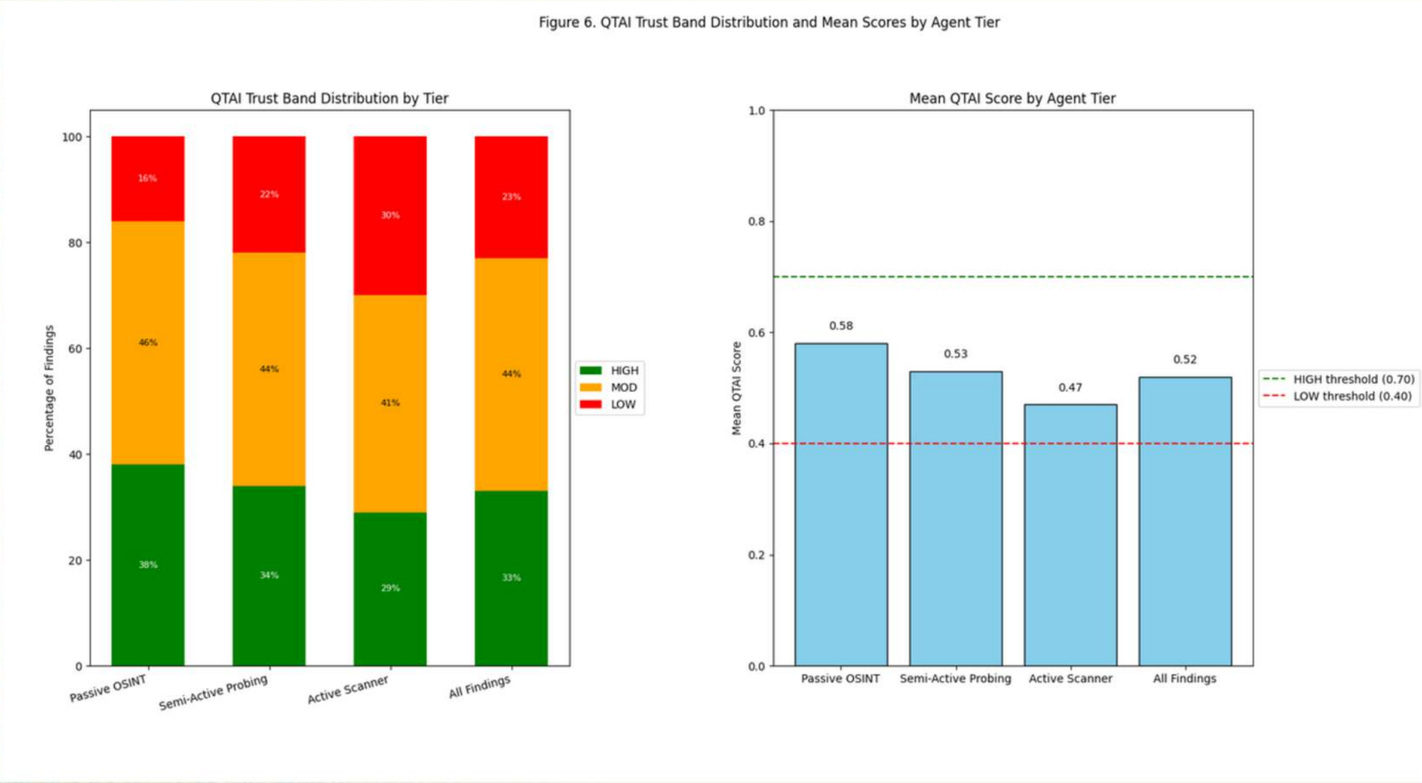


TABLE VIII: QTAI Trust Band Distribution by Agent Tier

Agent Tier	HIGH	MOD	LOW	Mean QTAI
Passive OSINT	38%	46%	16%	0.58
Semi-Active Probing	34%	44%	22%	0.53
Active Scanner	29%	41%	30%	0.47
All Findings (Combined)	33%	44%	23%	0.52

QUANTIFIABLE TRUST AND ACCOUNTABILITY INDEX FIDELITY

RINIG

RESULTS AND DISCUSSION

HUMAN-IN-THE-LOOP VALIDATION 2

TABLE IX: Participant Profiles (n=12)

ID	Cohort	Sec. Exp.	Default Module Access
P1	Bulong	None	Passive only
P2	Bulong	None	Passive only
P3	Bulong	< 6 months	Passive only
P4	Bulong	None	Passive only
P5	Dinig	1 year	Passive + Semi-Active
P6	Dinig	1–2 years	Passive + Semi-Active
P7	Dinig	2 years	Passive + Semi-Active
P8	Dinig	1 year	Passive + Semi-Active
P9	Sigaw	3 years	All 24 modules
P10	Sigaw	4 years	All 24 modules
P11	Sigaw	5 years	All 24 modules
P12	Sigaw	3–4 years	All 24 modules

Note. Sec. Exp. = self-reported years of cybersecurity experience. Participants were recruited through purposive sampling in online technical communities (e.g., Discord) and peer networks.

12 out of 10

PARTICIPANTS

RINIG

RESULTS AND DISCUSSION

HUMAN-IN-THE-LOOP VALIDATION 2

VALIDATING THE INSTRUMENT

1) Instrument Reliability: Prior to inferential analyses, internal consistency of the three 5-item Likert subscales was evaluated using Cronbach's α. The table below reports the reliability coefficients, all of which exceed $\alpha = 0.80$, indicating good internal consistency.

TABLE X: Internal Consistency of Likert Subscales

Instrument Subscale	Items	Cronbach's α	Interpretation
Trustworthiness (T)	5	0.835	Good
Rationale Comprehensibility (RC)	5	0.842	Good
Recon Framework Efficacy (RE)	5	0.818	Good

RINIG

RESULTS AND DISCUSSION

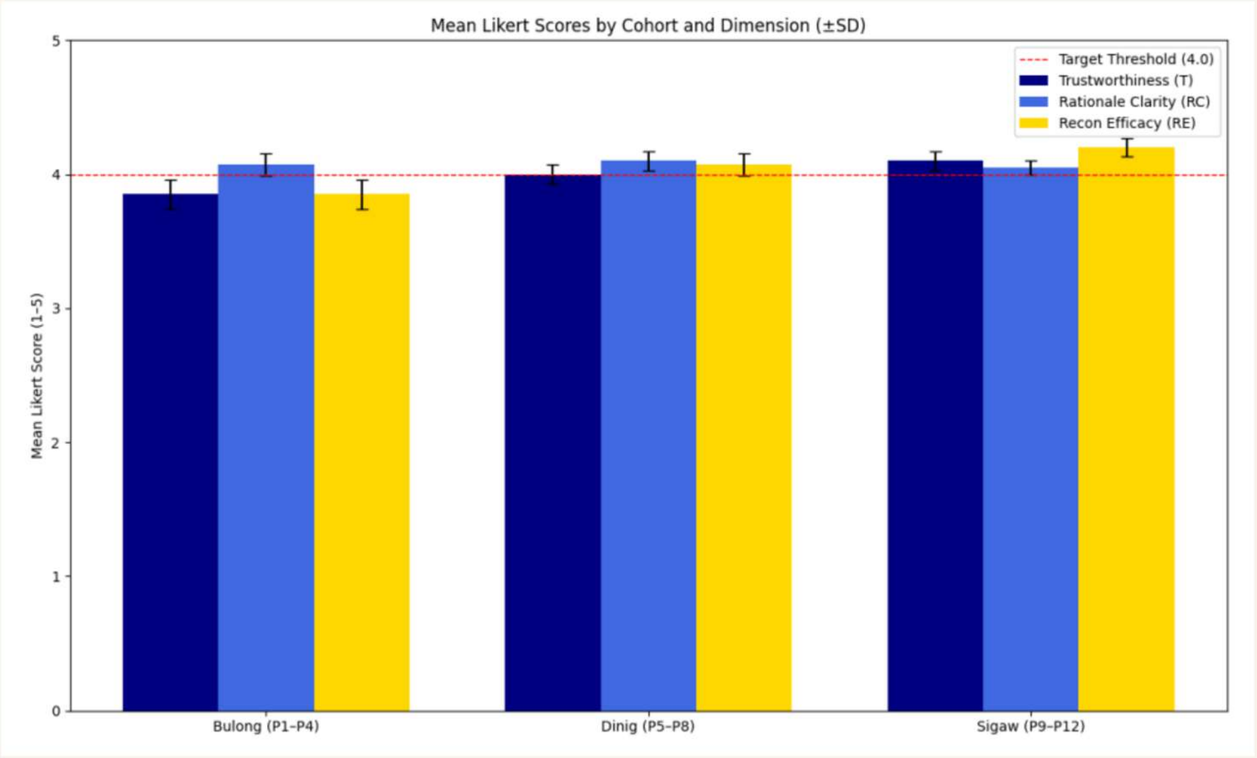
HUMAN-IN-THE-LOOP VALIDATION 2

DESCRIPTIVE STATISTICS: MEAN LIKERT

TABLE XI: Likert Ratings Mean (n=12)

Participant	Trust (T)	Rationale Clarity (RC)	Recon Efficacy (RE)
P1	3.7	4.0	3.8
P2	3.9	4.1	3.9
P3	4.0	4.2	4.0
P4	3.8	4.0	3.7
P5	4.0	4.1	4.0
P6	4.1	4.0	4.2
P7	3.9	4.2	4.1
P8	4.0	4.1	4.0
P9	4.2	4.0	4.3
P10	4.1	4.1	4.2
P11	4.0	4.0	4.1
P12	4.1	4.1	4.2

Ratings on 5-point Likert scale (1 = Strongly Disagree, 5 = Strongly Agree)



RINIG

RESULTS AND DISCUSSION

HUMAN-IN-THE-LOOP VALIDATION 2

DESCRIPTIVE STATISTICS: LEARNING GAIN

TABLE XII: Learning Gains (n=8)

Participant	Pre-Test	Post-Test	Learning Gain
P1	2.5	7.0	45%
P2	2.8	7.4	46%
P3	3.0	7.6	52%
P4	2.7	7.9	55%
P5	5.0	7.2	22%
P6	5.2	7.5	25%
P7	5.3	7.8	28%
P8	5.1	8.0	30%

Note. Learning Gain is based on the cumulative modules accomplished.

RINIG

CONSOLIDATED FINDINGS

- **As a reconaissance framework, RINIG has managed to show reliability across:** Detection Rate, Mean Noise Score, Stealth (Avoidance), Completion Time, RGE Coverage.

- **As a developer tool, RINIG has managed to gain user trust evident by:** Trust, Comprehensibility, Framework Efficiency and Learning Gains.

although limitations apply